SevaOne: Department Integration (WSO2)

Current implementation. How a department calls SevaOne: WSO2 API Manager, WSO2 Identity Server and the .NET backend.

Service · Request · Event or callback · Data store · Runs on a separate server

A SevaOne web portal

SevaOne citizen portal

React 19 · "Apply" button
Sends the citizen to the department

1 redirect + encrypted one-time token (30 min)

8 redirect back with completion token (10 min)

B Department systems

Department portal

The citizen completes the real form
and pays here, on the department's own site

Department backend

Server-to-server calls to SevaOne
Holds its ApiKey and Client ID / secret

3 POST /api/v1/dept/* · ApiKey + Bearer token

2 client_credentials, scope dept:<code> returns the Bearer token

C Edge

NGINX reverse proxy

Routes /api/v1/dept/* to the department API on the gateway

to the department API

D Gateway and identity

WSO2 API Manager 4.7

API "SevaOne-API" · gateway :8243 · /sevaone/1.0.0
Checks the ApiKey (api_key-only security scheme)
Stamps X-SevaOne-Dept-Gateway-Secret on dept/* calls

forward + secret

4

WSO2 Identity Server 7.3

One client_credentials app per department (11)
Scope dept:<code> names the department
Token endpoint and introspection endpoint :9443
Departments: revenue, health, rdpr, kaic, food, transport, education, social-welfare, wcd, labour, agriculture

introspect Bearer

5

E SevaOne backend (.NET 10)

Department endpoints under /api/v1/dept
user-details · payment-status · get-acknowledgement · status-update · test-token

1 DeptGatewayAuthMiddleware

Checks the stamped gateway secret. No secret, no entry: it fails closed.

2 DeptController: who is calling

Introspects the Bearer token, reads the dept:<code> scope, and checks the body departmentId matches.

3 DeptTokenGate: is the citizen token genuine

Decrypts the one-time token, looks up its hash, verifies the JWS signature and the department, and redeems it once.

cache the verdict (60 s) · keys — 6

token lookup · single-use redeem · application · status — 7

F Data

Redis 8

Introspection verdicts, kept at most 60 s
Data-protection keys (decrypt apply tokens)

PostgreSQL 18

portal.sevaone_token: hashed one-time tokens
orchestration.applications: the application row
status timeline and audit log